

Security+ 5.6 · Security Awareness

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 5.6 — Security Awareness (6:45)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Phishing campaigns (simula e mensura); reporting options (botão de 'reportar' fácil); user training (contínuo, não só anual); anomalous behavior recognition.

Highlights que a prova cobra

- Simulated phishing: o melhor treino — clica e aprende
- Reporting fácil = taxa de reporte real (a métrica que importa)

Dicas de prova & Cenários Típicos

- 'simulated phishing email sent to measure employee awareness'=phishing campaign

Cenário clássico de exame: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign.

Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 5.6 — Security Awareness)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:

- A)** Escassez
- B)** Autoridade + urgência
- C)** Prova social
- D)** Reciprocidade

2. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?

- A) Vishing**
- B) Pretexting**
- C) Baiting**
- D) Tailgating**

3. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Simulated phishing: o melhor treino — clica e aprende'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Substituir controles técnicos preventivos por termos de adesão informais**
- C) Implementar a solução correspondente: Simulated phishing: o melhor treino — clica e aprende...**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

4. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Reporting fácil = taxa de reporte real (a métrica que importa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A) Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema**
- B) Implementar a solução correspondente: Reporting fácil = taxa de reporte real (a métrica que importa)...**
- C) Substituir controles técnicos preventivos por termos de adesão informais**
- D) Permitir acesso compartilhado entre administradores com credenciais genéricas**

5. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: "simulated phishing email sent to measure employee awareness"=phishing campaign'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'simulated phishing email sent to measure employee awareness'=phishing camp...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: "empresa manda email de phishing simulado e mede quantos clicaram"=phishing campaign.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Simulated phishing: o melhor treino — clica e aprende'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Simulated phishing: o melhor treino — clica e aprende...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Reporting fácil = taxa de reporte real (a métrica que importa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Reporting fácil = taxa de reporte real (a métrica que importa)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'simulated phishing email sent to measure employee awareness'=phishing campaign'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'simulated phishing email sent to measure employee awareness'=phishing camp...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) B — Autoridade + urgência.

✓ **Por que está certa:** A alternativa correta é 'Autoridade + urgência'. A engenharia social explora vieses cognitivos e princípios psicológicos para manipular vítimas. No cenário, o golpista se passa por suporte de TI, o que invoca o princípio da autoridade (a vítima tende a obedecer a figuras de autoridade). Além disso, ele cria um senso de urgência para pressionar a vítima a agir rapidamente, sem pensar criticamente. A combinação de autoridade e urgência é uma tática clássica de engenharia social, reconhecida pela CompTIA. Portanto, a opção 'Autoridade + urgência' descreve com precisão os princípios explorados.

✗ **Por que as outras estão erradas:**

- *Escassez:* Escassez é um princípio de persuasão que explora a percepção de que recursos são limitados, criando uma sensação de que a oportunidade pode ser perdida se não agir imediatamente. No cenário, não há menção a recursos escassos ou ofertas limitadas. O golpista não está oferecendo algo em quantidade limitada, mas sim se passando por autoridade e criando urgência. Portanto, escassez não é o princípio aplicável.
- *Prova social:* Prova social é a tendência de as pessoas seguirem o comportamento dos outros, assumindo que ações tomadas por muitos são corretas. No ataque descrito, não há menção a outras pessoas fazendo o mesmo ou endossando a ação. O golpista não usa a ideia de que 'todos estão fazendo' para convencer a vítima. Portanto, prova social não é o princípio explorado.
- *Reciprocidade:* Reciprocidade é o princípio de que as pessoas se sentem obrigadas a retribuir um favor ou concessão. No cenário, o golpista não oferece nada primeiro para depois pedir a senha; ele simplesmente se passa por suporte e cria urgência. Não há troca de favores. Portanto, reciprocidade não se aplica.

2) A — Vishing.

✓ **Por que está certa:** A alternativa correta é 'Vishing'. Vishing é a combinação de 'voice' e 'phishing', ou seja, engenharia social realizada por meio de chamadas telefônicas (VoIP ou rede telefônica tradicional). No cenário descrito, o atacante se passa por suporte técnico para obter a senha da vítima, caracterizando exatamente um ataque de vishing. A CompTIA Security+ classifica vishing como um ataque de engenharia social baseado em voz, onde a interação em tempo real aumenta a pressão psicológica e a credibilidade percebida. O objetivo é induzir a vítima a revelar credenciais ou executar ações prejudiciais.

✗ **Por que as outras estão erradas:**

- *Pretexting:* Pretexting é a criação de um cenário ou pretexto falso para obter informações. Embora o atacante no enunciado use um pretexto (falso suporte técnico), o vetor principal é o telefone. Pretexting é um elemento comum em muitos ataques de engenharia social, incluindo vishing, phishing e smishing. A alternativa é incorreta porque não especifica o canal telefônico, que é a característica definidora do vishing. Em termos técnicos, pretexting é a técnica de construção da história, enquanto vishing é o meio de entrega via voz.
- *Baiting:* Baiting envolve deixar um dispositivo físico (como um pendrive infectado) ou uma isca digital para que a vítima o utilize, explorando a curiosidade. Não há relação com chamadas telefônicas ou solicitação direta de senha por voz. A alternativa é incorreta porque descreve um ataque que depende de ação física ou interação com mídia removível, não de interação verbal em tempo real.
- *Tailgating:* Tailgating é uma técnica de acesso físico não autorizado em que o atacante segue um funcionário autorizado através de uma porta segura sem se autenticar. Não envolve telefone, engenharia social verbal ou obtenção de senha. A alternativa é incorreta porque pertence à

categoria de ataques físicos, enquanto o cenário descreve um ataque remoto de engenharia social por voz.

3) C — Implementar a solução correspondente: Simulated phishing: o melhor treino — clica e aprende....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): Simulated phishing: o melhor treino — clica e aprende.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) B — Implementar a solução correspondente: Reporting fácil = taxa de reporte real (a métrica que importa)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): Reporting fácil = taxa de reporte real (a métrica que importa).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) A — Implementar a solução correspondente: 'simulated phishing email sent to measure employee awareness'=phishing camp....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): 'simulated phishing email sent to measure employee awareness'=phishing campaign.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) B — Implementar a solução correspondente: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) B — Implementar a solução correspondente: Simulated phishing: o melhor treino — clica e aprende....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): Simulated phishing: o melhor treino — clica e aprende.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) A — Implementar a solução correspondente: Reporting fácil = taxa de reporte real (a métrica que importa)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): Reporting fácil = taxa de reporte real (a métrica que importa).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) A — Implementar a solução correspondente: 'simulated phishing email sent to measure employee awareness'=phishing camp....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): 'simulated phishing email sent to measure employee awareness'=phishing campaign.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.